CHAPTER

SYSC 3 Systems and controls

Section : SYSC 3.1 Systems and controls

SYSC 3.1.1 R

A *firm* must take reasonable care to establish and maintain such systems and controls as are appropriate to its business.

SYSC 3.1.2 G

(1) The nature and extent of the systems and controls which a *firm* will need to maintain under *SYSC 3.1.1 R* will depend upon a variety of factors including:

(a) the nature, scale and complexity of its business;

(b) the diversity of its operations, including geographical diversity;

(c) the volume and size of its transactions; and

(d) the degree of risk associated with each area of its operation.

(2) To enable it to comply with its obligation to maintain appropriate systems and controls, a *firm* should carry out a regular review of them.

(3) The areas typically covered by the systems and controls referred to in *SYSC 3.1.1 R* are those identified in *SYSC 3.2*. Detailed requirements regarding systems and controls relevant to particular business areas or particular types of *firm* are covered elsewhere in the *Handbook*.

SYSC 3.1.2A G

Firms should also consider the additional *guidance* on risk-centric governance arrangements for effective risk management contained in *SYSC 21*.

SYSC 3.1.3 G

Where the *UK Corporate Governance Code* is relevant to a *firm*, the *appropriate regulator*, in considering whether the *firm's* obligations under *SYSC 3.1.1 R* have been met, will give it due credit for following corresponding provisions in the code.

SYSC 3.1.4 G

A *firm* has specific responsibilities regarding its *appointed representatives* or, where applicable, its *tied agents* (see *SUP 12*).

SYSC 3.1.5 G

SYSC 2.1.3 R (2) prescribes how a *firm* must allocate the function of overseeing the establishment and maintenance of systems and controls described in *SYSC 3.1.1 R*.

Competent employees rule

SYSC 3.1.6 R

A *firm* must employ personnel with the skills, knowledge and expertise necessary for the discharge of the responsibilities allocated to them.

SYSC 3.1.7 R

When complying with the *competent employees rules*, a *firm* must take into account the nature, scale and complexity of its business and the nature and range of financial services and activities undertaken in the course of that business.

SYSC 3.1.7A G

SYSC 28 contains *rules* and *guidance* on knowledge and competence in relation to *insurance distribution activities* undertaken by a *firm*.

SYSC 3.1.8 G The Training and Competence sourcebook (*TC*) contains additional *rules* and *guidance* relating to specified retail activities undertaken by a *firm*.

SYSC 3.1.9 G *Firms* which are carrying on activities that are not subject to *TC* may nevertheless wish to take *TC* into account in complying with the competence requirements in *SYSC*.

SYSC 3.1.10 G If a *firm* requires *employees* who are not subject to a qualification requirement in *TC* to pass a relevant examination from the list of appropriate qualifications maintained by the *FCA*, the *appropriate regulator* will take that into account when assessing whether the *firm* has ensured that the *employee* satisfies the knowledge component of the *competent employees rule*.

Insurance distribution activities

SYSC 3.1.11 R A *firm* carrying on *insurance distribution activities* must approve, implement and regularly review its internal policies and procedures in respect of its obligations under *SYSC 28*.
[**Note:** first paragraph of article 10(8) of the *IDD*]

SYSC 3.1.12 G *SYSC 2.1.6AR* prescribes how a *firm* must allocate the function of ensuring the proper implementation of the policies and procedures approved in accordance with *SYSC 3.1.11R*.

Section : SYSC 3.2 Areas covered by systems and controls

Introduction

SYSC 3.2.1 G This section covers some of the main issues which a *firm* is expected to consider in establishing and maintaining the systems and controls appropriate to its business, as required by *SYSC 3.1.1 R*.

Organisation

SYSC 3.2.2 G A *firm's* reporting lines should be clear and appropriate having regard to the nature, scale and complexity of its business. These reporting lines, together with clear management responsibilities, should be communicated as appropriate within the *firm*.

SYSC 3.2.3 G

(1) A *firm's governing body* is likely to delegate many functions and tasks for the purpose of carrying out its business. When functions or tasks are delegated, either to *employees* or to *appointed representatives* or, where applicable, its *tied agents*, appropriate safeguards should be put in place.

(2) When there is delegation, a *firm* should assess whether the recipient is suitable to carry out the delegated function or task, taking into account the degree of responsibility involved.

(3) The extent and limits of any delegation should be made clear to those concerned.

(4) There should be arrangements to supervise delegation, and to monitor the discharge of delegates functions or tasks.

(5) If cause for concern arises through supervision and monitoring or otherwise, there should be appropriate follow-up action at an appropriate level of seniority within the *firm*.

SYSC 3.2.4 G

(1) The *guidance* relevant to delegation within the *firm* is also relevant to external delegation ('outsourcing'). A *firm* cannot contract out its regulatory obligations. So, for example, under *Principle* 3 a *firm* should take reasonable care to supervise the discharge of outsourced functions by its contractor.

(2) A *firm* should take steps to obtain sufficient information from its contractor to enable it to assess the impact of outsourcing on its systems and controls.

SYSC 3.2.5 G Where it is made possible and appropriate by the nature, scale and complexity of its business, a *firm* should segregate the duties of individuals and departments in such a way as to reduce opportunities for *financial crime* or contravention of requirements and standards under the *regulatory system*. For example, the duties of front-office and back-office staff should be segregated so as to prevent a single individual initiating, processing and controlling transactions.

Systems and controls in relation to compliance, financial crime and money laundering

SYSC 3.2.6 R A *firm* must take reasonable care to establish and maintain effective systems and controls for compliance with applicable requirements and standards under the *regulatory system* and for countering the risk that the *firm* might be used to further *financial crime*.

SYSC 3.2.6A R A *firm* must ensure that these systems and controls:

(1) enable it to identify, assess, monitor and manage *money laundering* risk; and

(2) are comprehensive and proportionate to the nature, scale and complexity of its activities.

SYSC 3.2.6B G "*Money laundering* risk" is the risk that a *firm* may be used to further *money laundering*. Failure by a *firm* to manage this risk effectively will increase the risk to society of crime and terrorism.

SYSC 3.2.6C R A *firm* must carry out regular assessments of the adequacy of these systems and controls to ensure that it continues to comply with *SYSC 3.2.6A R*.

SYSC 3.2.6D G A *firm* may also have separate obligations to comply with relevant legal requirements, including the *Terrorism Act 2000,* the *Proceeds of Crime Act 2002* and the *Money Laundering Regulations*. *SYSC 3.2.6 R* to *SYSC 3.2.6J G* are not relevant for the purposes of regulation 76(6) or 86(2) of the *Money Laundering Regulations*, *section 330(8)* of the Proceeds of Crime Act 2002 or *section 21A(6)* of the Terrorism Act 2000.

SYSC 3.2.6E G The *FCA*, when considering whether a breach of its *rules* on systems and controls against *money laundering* has occurred, will have regard to whether a *firm* has followed relevant provisions in the guidance for the *UK* financial sector issued by the Joint Money Laundering Steering Group.

SYSC 3.2.6F G In identifying its *money laundering* risk and in establishing the nature of these systems and controls, a *firm* should consider a range of factors, including:

(1) its customer, product and activity profiles;

(2) its distribution channels;

(3) the complexity and volume of its transactions;

(4) its processes and systems; and

(5) its operating environment.

SYSC 3.2.6G G A *firm* should ensure that the systems and controls include:

(1) appropriate training for its employees in relation to *money laundering*;

(2) appropriate provision of information to its *governing body* and senior management, including a report at least annually by that *firm's money laundering reporting officer* (*MLRO*) on the operation and effectiveness of those systems and controls;

(3) appropriate documentation of its risk management policies and risk profile in

relation to *money laundering*, including documentation of its application of those policies (see *SYSC 3.2.20 R* to *SYSC 3.2.22 G*);

(4) appropriate measures to ensure that *money laundering* risk is taken into account in its day-to-day operation, including in relation to:

(a) the development of new products;

(b) the taking-on of new customers; and

(c) changes in its business profile; and

(5) appropriate measures to ensure that procedures for identification of new customers do not unreasonably deny access to its services to potential customers who cannot reasonably be expected to produce detailed evidence of identity.

SYSC 3.2.6H R

A *firm* must allocate to a *director* or *senior manager* (who may also be the *money laundering reporting officer*) overall responsibility within the *firm* for the establishment and maintenance of effective anti-*money laundering* systems and controls.

The money laundering reporting officer

SYSC 3.2.6I R

A *firm* must:

(1) appoint an individual as *MLRO*, with responsibility for oversight of its compliance with the *FCA's rules* on systems and controls against *money laundering*; and

(2) ensure that its *MLRO* has a level of authority and independence within the *firm* and access to resources and information sufficient to enable him to carry out that responsibility.

SYSC 3.2.6J G

The job of the *MLRO* within a *firm* is to act as the focal point for all activity within the *firm* relating to anti-*money laundering*. The *FCA* expects that a *firm's MLRO* will be based in the *United Kingdom*.

Financial crime guidance

SYSC 3.2.6K G

The *FCA* provides *guidance* on steps that a *firm* can take to reduce the risk that it might be used to further *financial crime* in *FCG* (Financial Crime Guide: A firm's guide to countering financial crime risks) and *FCTR* (Financial Crime Thematic Reviews).

The compliance function

SYSC 3.2.7 G

(1) Depending on the nature, scale and complexity of its business, it may be appropriate for a *firm* to have a separate compliance function. The organisation and responsibilities of a compliance function should be documented. A compliance function should be staffed by an appropriate number of competent staff who are sufficiently independent to perform their duties objectively. It should be adequately resourced and should have unrestricted access to the *firm's* relevant records as well as ultimate recourse to its *governing body*.

(2) [deleted]

(3) [deleted]

SYSC 3.2.8 R

(1)

A *firm*, other than an *UK ISPV*, must allocate to a *director* or *senior manager* the function of:

1. (a) having responsibility for oversight of the *firm's* compliance; and
2. (b) reporting to the *governing body* in respect of that responsibility.

(2)

In (1) "compliance" means compliance with the *firm's* obligations under the *regulatory system* in relation to which the *FCA* has responsibility.

SYSC 3.2.9 G

SUP 10C.6.1R uses *SYSC 3.2.8R* to describe the *controlled function*, known as the *compliance oversight function*, of acting in the capacity of a *director* or *senior manager* to whom this function is allocated.

Conduct risk oversight (Lloyd's) function

SYSC 3.2.9A R

In relation to business done at Lloyd's, the *Society* must allocate to a *director* or *senior manager* the function of having responsibility for overseeing the conduct of business standards required of *managing agents* for which the *Society* has responsibility.

Risk assessment

SYSC 3.2.10 G

(1) Depending on the nature, scale and complexity of its business, it may be appropriate for a *firm* to have a separate risk assessment function responsible for assessing the risks that the *firm* faces and advising the *governing body* and *senior managers* on them.

(2) The organisation and responsibilities of a risk assessment function should be documented. The function should be adequately resourced and staffed by an appropriate number of competent staff who are sufficiently independent to perform their duties objectively.

(3) The term 'risk assessment function' refers to the generally understood concept of risk assessment within a *firm*, that is, the function of setting and controlling risk exposure. The risk assessment function is not an *FCA controlled function* itself, but *firms* it may fall under the *PRA* chief risk officer *controlled function*.

(4) Paragraphs (1) and (3) do not apply to a *Solvency II firm* and (2) only applies as if the term 'risk assessment function' was replaced by 'risk management function'.

(5) *Solvency II firms* are subject to requirements for an effective risk management system in PRA Rulebook: Solvency II firms: Conditions Governing Business 3.

(6) Also, PRA Rulebook: Solvency II firms: Insurance Senior Management Functions makes the chief risk function a *PRA controlled function*. The chief risk function is the function of having responsibility for overall management of the risk management system, as specified in PRA Rulebook: Solvency II firms: Conditions Governing Business 3.

(7) The *FCA* will take the requirements in (5) and (6) into account.

Management information

SYSC 3.2.11A G

(1) A *firm's* arrangements should be such as to furnish its *governing body* with the information it needs to play its part in identifying, measuring, managing and controlling risks of regulatory concern. Three factors will be the relevance, reliability and timeliness of that information.

(2) Risks of regulatory concern are those risks which relate to the fair treatment of the *firm's customers*, to the protection of *consumers*, to effective competition and to the integrity of the *UK financial system*. Risks which are relevant to the integrity of the *UK financial system* include risks which relate to its soundness, stability and resilience and to the use of the system in connection with *financial crime*.

SYSC 3.2.12 G

It is the responsibility of the *firm* to decide what information is required, when, and for whom, so that it can organise and control its activities and can comply with its regulatory obligations. The detail and extent of information required will depend on the nature, scale and complexity of the business.

Employees and agents

SYSC 3.2.13 G

A *firm's* systems and controls should enable it to satisfy itself of the suitability of anyone who acts for it.

SYSC 3.2.14 G

(1) *SYSC 3.2.13 G* includes assessing an individual's honesty, and competence. This assessment should normally be made at the point of recruitment. An individual's honesty need not normally be revisited unless something happens to make a fresh look appropriate.

(2) Any assessment of an individual's suitability should take into account the level of responsibility that the individual will assume within the *firm*. The nature of this assessment will generally differ depending upon whether it takes place at the start of the individual's recruitment, at the end of the probationary period (if there is one) or subsequently.

(3) [deleted]

(4) The requirements on *firms* with respect to *approved persons* are in *Part V* of the *Act* (Performance of regulated activities) and *SUP 10C* and the Senior Insurance Management Functions parts of the *PRA Rulebook*

Audit committee

SYSC 3.2.15 G

Depending on the nature, scale and complexity of its business, it may be appropriate for a *firm* to form an audit committee. An audit committee could typically examine management's process for ensuring the appropriateness and effectiveness of systems and controls, examine the arrangements made by management to ensure compliance with requirements and standards under the *regulatory system*, oversee the functioning of the internal audit function (if applicable - see *SYSC 3.2.16 G*) and provide an interface between management and the external auditors. It should have an appropriate number of *non-executive directors* and it should have formal terms of reference.

Internal audit

SYSC 3.2.16 G

(1) Depending on the nature, scale and complexity of its business, it may be appropriate for a *firm* to delegate much of the task of monitoring the appropriateness and effectiveness of its systems and controls to an internal audit function. An internal audit function should have clear responsibilities and reporting lines to an audit committee or appropriate *senior manager*, be adequately resourced and staffed by competent individuals, be independent of the day-to-day activities of the *firm* and have appropriate access to a *firm's* records.

(2) The term 'internal audit function' refers to the generally understood concept of internal audit within a *firm*, that is, the function of assessing adherence to and the effectiveness of internal systems and controls, procedures and policies. The internal audit function is not an *FCA controlled function* itself, but for certain *firms* it may fall under the *PRA* chief risk officer *controlled function*.

(3) Paragraph (1) does not apply to *Solvency II firms*.

(4) *Solvency II firms* are subject to a requirement in PRA Rulebook: Solvency II firms: Conditions Governing Business, rule 5 to have an effective internal audit function.

(5) Also, the PRA Rulebook: Solvency II firms: Insurance Senior Management Functions makes the chief internal audit function a *PRA controlled function*. The chief internal audit function is the function of having responsibility for management of the internal audit function specified in PRA Rulebook: Solvency II firms: Conditions Governing Business, rule 5.

(6) The *FCA* will take the requirements in (4) and (5) into account.

Business strategy

SYSC 3.2.17 G

A *firm* should plan its business appropriately so that it is able to identify, measure, manage and control risks of regulatory concern (see *SYSC 3.2.11 G (2)*). In some *firms*, depending on the nature, scale and complexity of their business, it may be appropriate to have business plans or strategy plans documented and updated on a regular basis to take account of changes in the business environment.

Remuneration policies

SYSC 3.2.18 G

It is possible that *firms'* remuneration policies will from time to time lead to tensions between the ability of the *firm* to meet the requirements and standards under the *regulatory system* and the personal advantage of those who act for it. Where tensions exist, these should be appropriately managed. See also *Solvency II Regulation* (Article 275) and *EIOPA* Guidelines on system of governance dated 28 January 2015 (EIOPA-BoS-14/253 EN) (Guidelines 9 and 10).

Business continuity

SYSC 3.2.19 G

A *firm*, other than a *Solvency II firm*, should have in place appropriate arrangements, having regard to the nature, scale and complexity of its business, to ensure that it can continue to function and meet its regulatory obligations in the event of unforeseen interruption. These arrangements should be regularly updated and tested to ensure their effectiveness.

Solvency II firms are subject to the business continuity requirements in PRA Rulebook: Solvency II firms: Conditions Governing Business, 2.6, and the *FCA* will take those requirements into account.

Records

SYSC 3.2.20 R

(1) A *firm* must take reasonable care to make and retain adequate records of matters and dealings (including accounting records) which are the subject of requirements and standards under the *regulatory system*.

(2) Subject to (3) and to any other record-keeping *rule* in the *Handbook*, the records required by (1) or by such other *rule* must be capable of being reproduced in the English language on paper.

(3) If a *firm's* records relate to business carried on from an establishment in a country or territory outside the *United Kingdom*, an official language of that country or territory may be used instead of the English language as required by (2).

SYSC 3.2.21 G

A *firm* should have appropriate systems and controls in place to fulfil the *firm's* regulatory and statutory obligations with respect to adequacy, access, periods of retention and security of records. The general principle is that records should be retained for as long as is relevant for the purposes for which they are made.

SYSC 3.2.21A G

SYSC 28 contains *rules* and *guidance* on knowledge and competence record keeping in relation to *insurance distribution activities* undertaken by a *firm*.

SYSC 3.2.22 G

Detailed record-keeping requirements for different types of *firm* are to be found elsewhere in the *Handbook*. Schedule 1 to the Handbook is a consolidated schedule of these requirements.

Investment strategy and investment decision making

SYSC 3.2.23 G

(1) This *guidance* sets out the *FCA's* expectation on how a *firm* may take into account *ESG financial considerations* and *other financial considerations* and *non-financial matters* as part of its *investment* strategy and *investment* decision making, to demonstrate compliance with *Principles* 2, 3, 6 or 8.

(2) This *guidance* only applies where the *firm's investment* strategy or *investment* decision could have a material impact on a *policyholder's investment* returns and relates to a product where:

(a) the primary purpose is to provide an *investment* return; and

(b) any *investment* risk is borne by a *policyholder* who is a natural person or a *relevant policyholder*.

(3) As part of its *investment* strategy or *investment* decision making, a *firm* should take into account *ESG financial considerations* and *other financial considerations* over the period of time that the *firm* reasonably considers is needed to achieve the *investment* objective or *investment* strategy.

(4) References to *other financial considerations* in (3) may include (but are not limited to) interest rate, liquidity, concentration, exchange rate, political and counterparty risks.

(5) As part of its *investment* strategy or *investment* decision making in relation to a product, a *firm* may take into account *non-financial matters* if:

(a) the *firm* has good reason to consider that affected *policyholders* or *relevant policyholders* would generally share the views on which the *non-financial matters* are based; and

(b) taking those matters into account would not involve a risk of a significant financial detriment to any affected *investment*.

(6) (5) does not apply to a *firm's investment* strategy or *investment* decision making in relation to a product (other than in relation to a *relevant scheme* or a *pathway investment*), that has been deliberately designed by the *firm* to take into account *non-financial matters*, and *policyholders* or *relevant policyholders* make an active decision to select that product.

Operators of pensions dashboard services: security, integrity and confidentiality

SYSC 3.2.24 R

A *firm* carrying on *regulated pensions dashboard activity* must comply with the requirements set out in *SYSC 4.1.5AR*, *SYSC 4.1.5BR* and *SYSC 4.1.5CR* as if those *rules* applied to *firms* to which *SYSC 3* applies.

Section : SYSC 3.3 Additional requirements for insurance distribution

Application

SYSC 3.3.1 R *SYSC 3.3* applies to an *insurer* in the course of it carrying on any *insurance distribution activities*.

Identifying conflicts

SYSC 3.3.5 R A *firm* must take all appropriate steps to identify conflicts of interest that arise between:

(1) the *firm*, including its managers, employees and *appointed representatives* (or where applicable, *tied agents*), or any *person* directly or indirectly linked to it by *control*, and a *client* of the *firm*; or

(2) one *client* of the *firm* and another *client*.

[**Note:** article 28(1) of the *IDD*]

SYSC 3.3.6 R For the purposes of identifying, in accordance with *SYSC 3.3.5R* and *SYSC 3.3.13R*, the types of conflicts of interest that arise in the course of carrying out any *insurance distribution activities* related to *policies* and which entail a risk of damage to the interests of a *client*, a *firm* must assess whether it, a *relevant person* or any *person* directly or indirectly linked to it by *control*, has an interest in the outcome of the *insurance distribution activities*, which meets the following criteria:

(1) it is distinct from the *client's* or potential *client's* interest in the outcome of the *insurance distribution activities*;

(2) it has the potential to influence the outcome of the *insurance distribution activities* to the detriment of the *client*.

A *firm* must proceed in the same way for the purposes of identifying conflicts of interest between one *client* and another.

SYSC 3.3.7 R For the purposes of the assessment in *SYSC 3.3.6R*, a *firm* must take into account, by way of minimum criteria, the following situations:

(1) the *firm*, a *relevant person* or any *person* directly or indirectly linked to it by *control* is likely to make a financial gain, or avoid a financial loss, to the potential detriment of the *client*;

(2) the *firm*, a *relevant person* or any *person* directly or indirectly linked to it by *control* has a financial or other incentive to favour the interest of another *client* or group of *clients* over the interest of the *client*;

(3) the *firm*, a *relevant person* or any *person* directly or indirectly linked by *control* to the *firm* is substantially involved in the management or development of *policies*, in particular where such a *person* has an influence on the pricing of those *policies* or their distribution costs.

[**Note:** article 3 of the *IDD Regulation*]

Managing conflicts

SYSC 3.3.8 R

A *firm* must maintain and operate effective organisational and administrative arrangements with a view to taking all reasonable steps designed to prevent conflicts of interest identified under *SYSC 3.3.5R* from adversely affecting the interests of its *clients*.

[**Note:** article 27 of the *IDD*]

Proportionality

SYSC 3.3.9 R

The arrangements in *SYSC 3.3.8R* must be proportionate to the activities performed, the *policies* sold and the type of *insurance distributor* the *firm* is or uses.

[**Note:** article 27 of the *IDD*]

Conflicts policy

SYSC 3.3.10 R

(1) For the purposes of *SYSC 3.3.8R* and *SYSC 3.3.9R*, a *firm* must establish, implement and maintain an effective conflicts of interest policy set out in writing and appropriate to its size and organisation and the nature, scale and complexity of its business.

(2) Where the *firm* is a member of a group, the policy must also take into account any circumstances, of which the *firm* is or should be aware, which may give rise to a conflict of interest arising as a result of the structure and business activities of other members of the group.

[**Note:** article 4(1) of the *IDD Regulation*]

Contents of policy

SYSC 3.3.11 R

The conflicts of interest policy required in *SYSC 3.3.10R* must include the following content:

(1) with reference to the specific *insurance distribution activities* carried out, the circumstances which constitute or may give rise to a conflict of interest entailing a risk of damage to the interests of one or more *clients*;

(2) procedures to be followed and measures to be adopted in order to manage such conflicts and prevent them from damaging the interests of the *client*.

[**Note:** article 4(2) of the *IDD Regulation*]

SYSC 3.3.12 R

(1) The procedures and measures required in *SYSC 3.3.11R(2)* must be appropriate to the size and activities of the *firm* and of the group to which it may belong, and to the risk of damage to the interests of the *client*.

(2) The procedures to be followed and measures required in *SYSC 3.3.11R(2)* must include, where appropriate, the following:

(a) effective procedures to prevent or control the exchange of information between *relevant persons* engaged in activities involving a risk of conflict of interest where the exchange of that information may damage the interests of one or more *clients*;

(b) the separate supervision of *relevant persons* whose principal functions involve carrying out activities on behalf of, or providing services, to *clients* whose interests may conflict, or who otherwise represent different interests

that may conflict, including those of the *firm*;

(c) the removal of any direct link between payments, including *remuneration*, to *relevant persons* engaged in one activity and payments, including *remuneration*, to different *relevant persons* principally engaged in another activity, where a conflict of interest may arise in relation to those activities;

(d) measures to prevent or limit any *person* from exercising inappropriate influence over the way in which *insurance distribution activities* are carried out by the *firm* or its managers or employees or any *person* directly or indirectly linked to it by *control*;

(e) measures to prevent or control the simultaneous or sequential involvement of a *relevant person* in separate *insurance distribution activities* where such involvement may impair the proper management of conflicts of interest;

(f) a gifts and benefits policy which determines clearly under which conditions gifts and benefits can be accepted or granted and which steps are to be taken when accepting and granting gifts and benefits.

(3) Where the *firm* can demonstrate that the measures and procedures referred to in (1) and (2) are not appropriate to ensure that the *insurance distribution activities* are carried out in accordance with the best interest of the *client* and are not biased due to conflicting interests of the *firm*, an *insurance intermediary* or another *client*, the *firm* must adopt adequate alternative measures and procedures for that purpose.

[**Note:** article 5 of the *IDD Regulation*]

Disclosure of conflicts

SYSC 3.3.13 R

(1) If arrangements made under *SYSC 3.3.8R* are not sufficient to ensure, with reasonable confidence, that risks of damage to the interests of a *client* will be prevented, the *firm* must:

(a) clearly disclose to the *client* the general nature or sources of the conflicts of interest (or both); and

(b) include sufficient detail in the disclosure, taking into account the nature of the *client*, to enable that *client* to take an informed decision with respect to the *insurance distribution activities* in the context of which the conflict of interest arises.

(2) The disclosure must be made:

(a) in a *durable medium*; and

(b) in good time before the conclusion of the *contract of insurance*.

[**Note:** article 28(2) and (3) of the *IDD*]

SYSC 3.3.14 R

(1) A *firm* must avoid over-reliance on disclosure to ensure that disclosure to *clients*, under *SYSC 3.3.13R* is a measure of last resort that can be used only where the effective organisational and administrative arrangements established by the *firm* to prevent or manage conflicts of interest in accordance with *SYSC 3.3.8R* and *SYSC 3.3.9R* are not sufficient to ensure, with reasonable confidence, that risks of damage

to the interests of the *client* will be prevented.

(2) For the purposes of a disclosure of conflicts of interest a *firm* must:

(a) provide a specific description of the conflict of interest in question;

(b) explain the general nature and sources of the conflict of interest;

(c) explain the risks to the *client* that arise as a result of the conflict of interest and the steps undertaken to mitigate those risks;

(d) clearly state that the organisational and administrative arrangements established by the *firm* to prevent or manage the conflict of interest are not sufficient to ensure, with reasonable confidence, that risks of damage to the interests of the *client* will be prevented.

[**Note:** article 6 of the *IDD Regulation*]

Review of conflicts policy

SYSC 3.3.15 R

For the purposes of *SYSC 3.3.8R*, a *firm* must assess and periodically review, on an at least annual basis, the conflicts of interest policy established in accordance with *SYSC 3.3.10R* and take all appropriate measures to address any deficiencies.

[**Note:** article 7(1) of the *IDD Regulation*]

Record keeping

SYSC 3.3.16 R

(1) A *firm* must keep and regularly update a record of the situations in which a conflict of interest entailing a risk of damage to the interests of a *client* has arisen or, in the case of an ongoing service or activity may arise.

(2) A *firm* must ensure its senior management receives on a frequent basis, and at least annually, written reports on the situations referred to in (1).

[**Note:** article 7(2) of the *IDD Regulation*]

SYSC 3.3.17 R

A *firm* carrying on *insurance distribution activities* in relation to *insurance-based investment products* must retain its records relating to:

(1) suitability (*COBS 9A*); and

(2) appropriateness (*COBS 10A*),

for a period of at least five years.

SYSC 3.3.18 G

(1) *COBS 9A.4* and *COBS 10A.7* (record keeping and retention periods for suitability and appropriateness records) contain record keeping requirements that specify information which should be recorded by *firms* in relation to *insurance-based investment products* and for how long the records must be retained.

(2) For the purposes of *SYSC 3.3.17R*, a *firm* will need to consider whether the requirement in *COBS 9A.4.3R* or *COBS 10A.7.2AR* means that a record needs to be retained for longer than five years.

SYSC 3.3.19 R

(1) The records required under *COBS 9A.4* and *COBS 10A.7* must be retained in a medium that allows the storage of information in a way accessible for future

reference by the *FCA*.

(2) The *FCA* must be able to access the records in (1) readily, to reconstitute each element in a clear and accurate manner and to identify easily any changes, corrections or other amendments, and the contents of the records prior to such modifications.

[**Note:** article 19(4) of the *IDD Regulation*]

Section : SYSC 3.4 SRD requirements

Application

SYSC 3.4.1 R This section applies to:

(a) a *UK insurer*; and

(b) a *UK pure reinsurer*,

doing *long-term insurance business*.

SYSC 3.4.2 R The *rules* in this section apply to the extent that a *firm* is investing (or has invested), directly or through an *SRD asset manager*, in shares traded on a *regulated market*.

SYSC 3.4.3 G The defined term *regulated market* has an extended meaning for the purposes of this section. The definition includes certain markets situated outside the *United Kingdom*.

Engagement policy and disclosure of information

SYSC 3.4.4 R A *firm* must either:

(1)

(a) develop and publicly disclose an *engagement policy* that meets the requirements of *SYSC 3.4.5R* (an "engagement policy"); and

(b) publicly disclose on an annual basis how its *engagement policy* has been implemented, in a way that meets the requirements of *SYSC 3.4.6R*; or

(2) publicly disclose a clear and reasoned explanation of why it has chosen not to comply with any of the requirements imposed by (1).

[**Note:** article 3g(1) and (1)(a) of *SRD*]

SYSC 3.4.5 R The *engagement policy* must describe how the *firm*:

(1) integrates shareholder engagement in its investment strategy;

(2) monitors investee companies on relevant matters, including:

(a) strategy;

(b) financial and non-financial performance and risk;

(c) capital structure; and

(d) social and environmental impact and corporate governance;

(3) conducts dialogues with investee companies;

(4) exercises voting rights and other rights attached to *shares*;

(5) cooperates with other shareholders;

(6) communicates with relevant stakeholders of the investee companies; and

(7) manages actual and potential conflicts of interests in relation to the *firm's* engagement.

[**Note:** article 3g(1)(a) of *SRD*]

SYSC 3.4.6 R

(1) The annual disclosure must include a general description of voting behaviour, an explanation of the most significant votes and the use of the services of *proxy advisors*.

(2)

(a) Subject to (b), a *firm* must publicly disclose how it has cast votes in the general meetings of companies in which it holds *shares*.

(b) A *firm* is not required to disclose votes that are insignificant due to the subject matter of the vote or the size of the holding in the company.

[**Note:** article 3g(1)(b) of *SRD*]

SYSC 3.4.7 R

(1) The applicable disclosures or information referred to in *SYSC 3.4.4R* to *SYSC 3.4.6R* must be made available free of charge on the *firm's* website.

(2) Where an *SRD asset manager* implements the engagement policy, including voting, on behalf of a *firm*, the *firm* must make a reference as to where such voting information has been published by the *SRD asset manager*.

[**Note:** article 3g(2) of *SRD*]

Investment strategy and arrangements with SRD asset managers

SYSC 3.4.8 R

A *firm* must disclose publicly how the main elements of its equity investment strategy are consistent with the profile and duration of its liabilities, in particular long-term liabilities, and how they contribute to the medium- to long-term performance of its assets.

[**Note:** article 3h(1) of *SRD*]

SYSC 3.4.9 R

(1) Where an *SRD asset manager* invests on behalf of a *firm*, whether on a discretionary client-by-client basis or through a collective investment undertaking, the *firm* must publicly disclose the following information regarding its arrangement with the *SRD asset manager*:

(a) how the arrangement with the *SRD asset manager* incentivises the *SRD asset manager* to align its investment strategy and decisions with the profile and duration of the liabilities of the *firm*, in particular long-term liabilities;

(b) how that arrangement incentivises the *SRD asset manager* to make investment decisions based on assessments of medium- to long-term financial and non-financial performance of the investee company, and to engage with investee companies in order to improve their performance in the medium- to long-term;

(c) how the method and time horizon of the evaluation of the *SRD asset manager's* performance and the remuneration for asset management services are in line with the profile and duration of the liabilities of the *firm*, in particular its long-term liabilities, taking into account its absolute long-term performance;

(d) how the *firm* monitors portfolio turnover costs incurred by the *SRD asset manager* and how it defines and monitors a targeted portfolio turnover or turnover range; and

(e) the duration of the arrangement with the *SRD asset manager*.

(2) Where the arrangement with the *SRD asset manager* does not contain one or more such elements, the *firm* must give a clear and reasoned explanation why this is the case.

[**Note:** article 3h(2) of *SRD*]

SYSC 3.4.10 R The information referred to in *SYSC 3.4.8R* and *SYSC 3.4.9R* must:

(1) be made available, free of charge, on the *firm's* website; and

(2) be updated annually, unless there is no material change.

[**Note:** article 3h(3), first paragraph of *SRD*]

CHAPTER

SYSC 13 Operational risk: systems and controls for insurers

Section : SYSC 13.1 Application

SYSC 13.1.1	G	*SYSC 13* applies to an *insurer* unless it is a *non-directive friendly society*.
SYSC 13.1.2	G	*SYSC 13* applies a *Swiss general insurer* only in respect of the activities of the *firm* carried on from a *branch* in the *United Kingdom*. only in respect of the activities of the *firm* carried on from a *branch* in the *United Kingdom*.
SYSC 13.1.3	G	*SYSC 13* applies to a *UK ISPV*.
SYSC 13.1.4	G	*SYSC 13* does not apply to an *incoming ECA provider* acting as such.

Section : SYSC 13.2 Purpose

SYSC 13.2.1 G

SYSC 13 provides *guidance* on how to interpret *SYSC 3.1.1 R* and *SYSC 3.2.6 R*, which deal with the establishment and maintenance of systems and controls, in relation to the management of operational risk. Operational risk has been described by the Basel Committee on Banking Supervision as "the risk of loss, resulting from inadequate or failed internal processes, people and systems, or from external events". This chapter covers systems and controls for managing risks concerning any of a *firm's* operations, such as its IT systems and *outsourcing* arrangements. It does not cover systems and controls for managing credit, market, liquidity and insurance risk.

SYSC 13.2.2 G

Operational risk is a concept that can have a different application for different *firms*. A *firm* should assess the appropriateness of the *guidance* in this chapter in the light of the scale, nature and complexity of its activities as well as its obligations as set out in *Principle* 3, to organise and control its affairs responsibly and effectively.

SYSC 13.2.3 G

A *firm* should take steps to understand the types of operational risk that are relevant to its particular circumstances, and the operational losses to which they expose the *firm*. This should include considering the potential sources of operational risk addressed in this chapter: people; processes and systems; external events.

SYSC 13.2.4A G

Operational risk can, amongst other things, lead to unfair treatment of consumers or lead to financial crime. A *firm* should consider all operational risk events that may affect these matters in establishing and maintaining its systems and controls.

Section : SYSC 13.3 Other related Handbook sections

SYSC 13.3.1A G

The following is a non-exhaustive list of *rules* and *guidance* in the *Handbook* that are relevant to a *firm's* management of operational risk:

(1) *COBS* contains *rules* and *guidance* that can relate to the management of operational risk; for example, *COBS 2* (Conduct of business obligations), *COBS 4* (Communicating with clients, including financial promotions), *COBS 6* (Information about the firm, its services and remuneration), *COBS 7* (Insurance distribution), *COBS 9* (Suitability (including basic advice)(other than MiFID and insurance-based investment products)), COBS 9A (Suitability (MiFID and insurance-based investment products provisions), COBS 10A (Appropriateness (for non-advised services) (MiFID and insurance-based investment products provisions), COBS 11 (Dealing and managing), *COBS 12* (Investment research), *COBS 14* (Providing product information to clients) and *COBS 19* (Pensions: supplementary provisions).

Section : SYSC 13.4 Requirements to notify the appropriate regulator

SYSC 13.4.1 G

Under *Principle* 11 and *SUP 15.3.1 R*, a *firm* must notify the *FCA* immediately of any operational risk matter of which the *FCA* would reasonably expect notice. *SUP 15.3.8 G* provides *guidance* on the occurrences that this requirement covers, which include a significant failure in systems and controls and a significant operational loss.

SYSC 13.4.2 G

Regarding operational risk, matters of which the *FCA* would expect notice under *Principle* 11 include:

(1) any significant operational exposures that a *firm* has identified;

(2) the *firm's* invocation of a business continuity plan; and

(3) any other significant change to a *firm's* organisation, infrastructure or business operating environment.

Section : SYSC 13.5 Risk management terms

SYSC 13.5.1 G

In this chapter, the following interpretations of risk management terms apply:

(1) a *firm's* risk culture encompasses the general awareness, attitude and behaviour of its *employees* and *appointed representatives* or, where applicable, its *tied agents*,to risk and the management of risk within the organisation;

(2) operational exposure means the degree of operational risk faced by a *firm* and is usually expressed in terms of the likelihood and impact of a particular type of operational loss occurring (for example, fraud, damage to physical assets);

(3) a *firm's* operational risk profile describes the types of operational risks that it faces, including those operational risks within a *firm* that may have an adverse impact upon the quality of service afforded to its *clients*, and its exposure to these risks.

Section : SYSC 13.6 People

SYSC 13.6.1 G

A *firm* should consult *SYSC 3.2.2 G* to *SYSC 3.2.5 G* for *guidance* on reporting lines and delegation of functions within a *firm* and *SYSC 3.2.13 G* to *SYSC 3.2.14 G* for *guidance* on the suitability of *employees* and *appointed representatives* or, where applicable, its *tied agents*. This section provides additional *guidance* on management of *employees* and other human resources in the context of operational risk.

SYSC 13.6.2 G

A *firm* should establish and maintain appropriate systems and controls for the management of operational risks that can arise from *employees*. In doing so, a *firm* should have regard to:

(1) its operational risk culture, and any variations in this or its human resource management practices, across its operations (including, for example, the extent to which the compliance culture is extended to in-house IT staff);

(2) whether the way *employees* are remunerated exposes the *firm* to the risk that it will not be able to meet its regulatory obligations (see *SYSC 3.2.18 G*). For example, a *firm* should consider how well remuneration and performance indicators reflect the *firm's* tolerance for operational risk, and the adequacy of these indicators for measuring performance;

(3) whether inadequate or inappropriate training of *client*-facing services exposes *clients* to risk of loss or unfair treatment including by not enabling effective communication with the *firm*;

(4) the extent of its compliance with applicable regulatory and other requirements that relate to the welfare and conduct of *employees*;

(5) its arrangements for the continuity of operations in the event of *employee* unavailability or loss;

(6) the relationship between indicators of 'people risk' (such as overtime, sickness, and *employee* turnover levels) and exposure to operational losses; and

(7) the relevance of all the above to *employees* of a third party supplier who are involved in performing an *outsourcing* arrangement. As necessary, a *firm* should review and consider the adequacy of the staffing arrangements and policies of a service provider.

Employee responsibilities

SYSC 13.6.3 G

A *firm* should ensure that all *employees* are capable of performing, and aware of, their operational risk management responsibilities, including by establishing and maintaining:

(1) appropriate segregation of *employees*' duties and appropriate supervision of *employees* in the performance of their responsibilities (see *SYSC 3.2.5 G*);

(2) appropriate recruitment and subsequent processes to review the fitness and propriety of *employees* (see *SYSC 3.2.13 G* and *SYSC 3.2.14 G*);

(3) clear policy statements and appropriate systems and procedures manuals that are effectively communicated to *employees* and available for *employees* to refer to as

required. These should cover, for example, compliance, IT security and health and safety issues;

(4) training processes that enable *employees* to attain and maintain appropriate competence; and

(5) appropriate and properly enforced disciplinary and employment termination policies and procedures.

SYSC 13.6.4 G A *firm* should have regard to *SYSC 13.6.3 G* in relation to *approved persons*, people occupying positions of high personal trust (for example, security administration, payment and settlement functions); and people occupying positions requiring significant technical competence (for example, *derivatives* trading and technical security administration). A *firm* should also consider the *rules* and *guidance* for *approved persons* in other parts of the *Handbook* (including *APER*, *COCON* and *SUP*) and the *rules* and *guidance* on *senior manager* responsibilities in *SYSC 2.1* (Apportionment of Responsibilities).

Section : SYSC 13.7 Processes and systems

SYSC 13.7.1 G

A *firm* should establish and maintain appropriate systems and controls for managing operational risks that can arise from inadequacies or failures in its processes and systems (and, as appropriate, the systems and processes of third party suppliers, agents and others). In doing so a *firm* should have regard to:

(1) the importance and complexity of processes and systems used in the end-to-end operating cycle for products and activities (for example, the level of integration of systems);

(2) controls that will help it to prevent system and process failures or identify them to permit prompt rectification (including pre-approval or reconciliation processes);

(3) whether the design and use of its processes and systems allow it to comply adequately with regulatory and other requirements;

(4) its arrangements for the continuity of operations in the event that a significant process or system becomes unavailable or is destroyed; and

(5) the importance of monitoring indicators of process or system risk (including reconciliation exceptions, compensation payments for *client* losses and documentation errors) and experience of operational losses and exposures.

Internal documentation

SYSC 13.7.2 G

Internal documentation may enhance understanding and aid continuity of operations, so a *firm* should ensure the adequacy of its internal documentation of processes and systems (including how documentation is developed, maintained and distributed) in managing operational risk.

External documentation

SYSC 13.7.3 G

A *firm* may use external documentation (including contracts, transaction statements or advertising brochures) to define or clarify terms and conditions for its products or activities, its business strategy (for example, including through press statements), or its brand. Inappropriate or inaccurate information in external documents can lead to significant operational exposure.

SYSC 13.7.4 G

A *firm* should ensure the adequacy of its processes and systems to review external documentation prior to issue (including review by its compliance, legal and marketing departments or by appropriately qualified external advisers). In doing so, a *firm* should have regard to:

(1) compliance with applicable regulatory and other requirements;

(2) the extent to which its documentation uses standard terms (that are widely recognised, and have been tested in the courts) or non-standard terms (whose meaning may not yet be settled or whose effectiveness may be uncertain);

(3) the manner in which its documentation is issued; and

(4) the extent to which confirmation of acceptance is required (including by *customer* signature or counterparty confirmation).

IT systems

SYSC 13.7.5 G IT systems include the computer systems and infrastructure required for the automation of processes, such as application and operating system software; network infrastructure; and desktop, server, and mainframe hardware. Automation may reduce a *firm's* exposure to some 'people risks' (including by reducing human errors or controlling access rights to enable segregation of duties), but will increase its dependency on the reliability of its IT systems.

SYSC 13.7.6 G A *firm* should establish and maintain appropriate systems and controls for the management of its IT system risks, having regard to:

(1) its organisation and reporting structure for technology operations (including the adequacy of senior management oversight);

(2) the extent to which technology requirements are addressed in its business strategy;

(3) the appropriateness of its systems acquisition, development and maintenance activities (including the allocation of responsibilities between IT development and operational areas, processes for embedding security requirements into systems); and

(4) the appropriateness of its activities supporting the operation of IT systems (including the allocation of responsibilities between business and technology areas).

Information security

SYSC 13.7.7 G Failures in processing information (whether physical, electronic or known by *employees* but not recorded) or of the security of the systems that maintain it can lead to significant operational losses. A *firm* should establish and maintain appropriate systems and controls to manage its information security risks. In doing so, a *firm* should have regard to:

(1) confidentiality: information should be accessible only to *persons* or systems with appropriate authority, which may require firewalls within a system, as well as entry restrictions;

(2) integrity: safeguarding the accuracy and completeness of information and its processing;

(3) availability and authentication: ensuring that appropriately authorised *persons* or systems have access to the information when required and that their identity is verified;

(4) non-repudiation and accountability: ensuring that the *person* or system that processed the information cannot deny their actions.

SYSC 13.7.8 G A *firm* should ensure the adequacy of the systems and controls used to protect the processing and security of its information, and should have regard to established security standards such as ISO17799 (Information Security Management).

Geographic location

SYSC 13.7.9 G

Operating processes and systems at separate geographic locations may alter a *firm's* operational risk profile (including by allowing alternative sites for the continuity of operations). A *firm* should understand the effect of any differences in processes and systems at each of its locations, particularly if they are in different countries, having regard to:

(1) the business operating environment of each country (for example, the likelihood and impact of political disruptions or cultural differences on the provision of services);

(2) relevant local regulatory and other requirements regarding data protection and transfer;

(3) the extent to which local regulatory and other requirements may restrict its ability to meet regulatory obligations in the *United Kingdom* (for example, access to information by the *FCA* and local restrictions on internal or external audit); and

(4) the timeliness of information flows to and from its headquarters and whether the level of delegated authority and the risk management structures of the overseas operation are compatible with the *firm's* head office arrangements.

Section : SYSC 13.8 External events and other changes

SYSC 13.8.1 G The exposure of a *firm* to operational risk may increase during times of significant change to its organisation, infrastructure and business operating environment (for example, following a corporate restructure or changes in regulatory requirements). Before, during, and after expected changes, a *firm* should assess and monitor their effect on its risk profile, including with regard to:

(1) untrained or de-motivated *employees* or a significant loss of *employees* during the period of change, or subsequently;

(2) inadequate human resources or inexperienced *employees* carrying out routine business activities owing to the prioritisation of resources to the programme or project;

(3) process or system instability and poor management information due to failures in integration or increased demand; and

(4) inadequate or inappropriate processes following business re-engineering.

SYSC 13.8.2 G A *firm* should establish and maintain appropriate systems and controls for the management of the risks involved in expected changes, such as by ensuring:

(1) the adequacy of its organisation and reporting structure for managing the change (including the adequacy of senior management oversight);

(2) the adequacy of the management processes and systems for managing the change (including planning, approval, implementation and review processes); and

(3) the adequacy of its strategy for communicating changes in systems and controls to its *employees*.

Unexpected changes and business continuity management

SYSC 13.8.3 G *SYSC 3.2.19 G* provides high level *guidance* on business continuity. This section provides additional *guidance* on managing business continuity in the context of operational risk.

SYSC 13.8.4 G The high level requirement for appropriate systems and controls at *SYSC 3.1.1 R* applies at all times, including when a business continuity plan is invoked. However, the *FCA* recognises that, in an emergency, a *firm* may be unable to comply with a particular *rule* and the conditions for relief are outlined in *GEN 1.3* (Emergency).

SYSC 13.8.5 G A *firm* should consider the likelihood and impact of a disruption to the continuity of its operations from unexpected events. This should include assessing the disruptions to which it is particularly susceptible (and the likely timescale of those disruptions) including through:

(1) loss or failure of internal and external resources (such as people, systems and other assets);

(2) the loss or corruption of its information; and

(3) external events (such as vandalism, war and "acts of God").

SYSC 13.8.6 G

A *firm* should implement appropriate arrangements to maintain the continuity of its operations. A *firm* should act to reduce both the likelihood of a disruption (including by succession planning, systems resilience and dual processing); and the impact of a disruption (including by contingency arrangements and insurance).

SYSC 13.8.7 G

A *firm* should document its strategy for maintaining continuity of its operations, and its plans for communicating and regularly testing the adequacy and effectiveness of this strategy. A *firm* should establish:

(1) formal business continuity plans that outline arrangements to reduce the impact of a short, medium or long-term disruption, including:

(a) resource requirements such as people, systems and other assets, and arrangements for obtaining these resources;

(b) the recovery priorities for the *firm's* operations; and

(c) communication arrangements for internal and external concerned parties (including the *FCA*, *clients* and the press);

(2) escalation and invocation plans that outline the processes for implementing the business continuity plans, together with relevant contact information;

(3) processes to validate the integrity of information affected by the disruption; and

(4) processes to review and update (1) to (3) following changes to the *firm's* operations or risk profile (including changes identified through testing).

SYSC 13.8.8 G

The use of an alternative site for recovery of operations is common practice in business continuity management. A *firm* that uses an alternative site should assess the appropriateness of the site, particularly for location, speed of recovery and adequacy of resources. Where a site is shared, a *firm* should evaluate the risk of multiple calls on shared resources and adjust its plans accordingly.

Section : SYSC 13.9 Outsourcing

SYSC 13.9.1 G

As *SYSC 3.2.4 G* explains, a *firm* cannot contract out its regulatory obligations and should take reasonable care to supervise the discharge of outsourced functions. This section provides additional *guidance* on managing *outsourcing* arrangements (and will be relevant, to some extent, to other forms of third party dependency) in relation to operational risk. *Outsourcing* may affect a *firm's* exposure to operational risk through significant changes to, and reduced control over, people, processes and systems used in outsourced activities.

SYSC 13.9.2 G

Firms should take particular care to manage *material outsourcing* arrangements and, as *SUP 15.3.8 G (1)(e)* explains, a *firm* should notify the *FCA* when it intends to enter into a *material outsourcing* arrangement.

SYSC 13.9.3 G

A *firm* should not assume that because a service provider is either a regulated *firm* or an intra-group entity an *outsourcing* arrangement with that provider will, in itself, necessarily imply a reduction in operational risk.

SYSC 13.9.4 G

Before entering into, or significantly changing, an *outsourcing* arrangement, a *firm* should:

(1) analyse how the arrangement will fit with its organisation and reporting structure; business strategy; overall risk profile; and ability to meet its regulatory obligations;

(2) consider whether the agreements establishing the arrangement will allow it to monitor and control its operational risk exposure relating to the *outsourcing*;

(3) conduct appropriate due diligence of the service provider's financial stability and expertise;

(4) consider how it will ensure a smooth transition of its operations from its current arrangements to a new or changed *outsourcing* arrangement (including what will happen on the termination of the contract); and

(5) consider any concentration risk implications such as the business continuity implications that may arise if a single service provider is used by several *firms*.

SYSC 13.9.5 G

In negotiating its contract with a service provider, a *firm* should have regard to:

(1) reporting or notification requirements it may wish to impose on the service provider;

(2) whether sufficient access will be available to its internal auditors, external auditors or *actuaries* (see *section 341* of the *Act*) and to the *FCA* (see *SUP 2.3.5 R* (Access to premises) and *SUP 2.3.7 R* (Suppliers under material outsourcing arrangements);

(3) information ownership rights, confidentiality agreements and *Chinese walls* to protect *client* and other information (including arrangements at the termination of the contract);

(4) the adequacy of any guarantees and indemnities;

(5) the extent to which the service provider must comply with the *firm's* policies and procedures (covering, for example, information security);

(6) the extent to which a service provider will provide business continuity for outsourced operations, and whether exclusive access to its resources is agreed;

(7) the need for continued availability of software following difficulty at a third party supplier;

(8) the processes for making changes to the *outsourcing* arrangement (for example, changes in processing volumes, activities and other contractual terms) and the conditions under which the *firm* or service provider can choose to change or terminate the *outsourcing* arrangement, such as where there is:

(a) a change of ownership or *control* (including insolvency or receivership) of the service provider or *firm*; or

(b) significant change in the business operations (including sub-contracting) of the service provider or *firm*; or

(c) inadequate provision of services that may lead to the *firm* being unable to meet its regulatory obligations.

SYSC 13.9.6 G

In implementing a relationship management framework, and drafting the service level agreement with the service provider, a *firm* should have regard to:

(1) the identification of qualitative and quantitative performance targets to assess the adequacy of service provision, to both the *firm* and its *clients*, where appropriate;

(2) the evaluation of performance through service delivery reports and periodic self certification or independent review by internal or external auditors; and

(3) remedial action and escalation processes for dealing with inadequate performance.

SYSC 13.9.7 G

In some circumstances, a *firm* may find it beneficial to use externally validated reports commissioned by the service provider, to seek comfort as to the adequacy and effectiveness of its systems and controls. The use of such reports does not absolve the *firm* of responsibility to maintain other oversight. In addition, the *firm* should not normally have to forfeit its right to access, for itself or its agents, to the service provider's premises.

SYSC 13.9.8 G

A *firm* should ensure that it has appropriate contingency arrangements to allow business continuity in the event of a significant loss of services from the service provider. Particular issues to consider include a significant loss of resources at, or financial failure of, the service provider, and unexpected termination of the *outsourcing* arrangement.

SYSC 13.9.9 G

(1) Parts of the *guidance* in *SYSC 13.9* do not apply to a *Solvency II firm*. They are *SYSC 13.9.3G*, *SYSC 13.9.4G*(1), (2), (4) and (5) and *SYSC 13.9.5G(6)*.

(2) A *Solvency II firm* is subject to the outsourcing requirements in PRA Rulebook: Solvency II firms: Conditions Governing Business 7.

(3) The *Solvency II Regulation* (EU) 2015/35 of 10 October 2014 (article 274) also

imposes specific requirements on *firms* which outsource, or propose to outsource, functions or insurance activities.

(4) *EIOPA* guidelines on systems of governance dated 28 January 2015 (EIOPA-BoS-14/253 EN) include guidelines on, or relating to, outsourcing.

(5) The *FCA* will take the requirements and guidelines in (2) to (4) into account when considering a *firm's* outsourcing arrangements.

Section : SYSC 13.10 Insurance

SYSC 13.10.1 G

Whilst a *firm* may take out insurance with the aim of reducing the monetary impact of operational risk events, non-monetary impacts may remain (including impact on the *firm's* reputation). A *firm* should not assume that insurance alone can replace robust systems and controls.

SYSC 13.10.2 G

When considering utilising insurance, a *firm* should consider:

(1) the time taken for the *insurer* to pay claims (including the potential time taken in disputing cover) and the *firm's* funding of operations whilst awaiting payment of claims;

(2) the financial strength of the *insurer*, which may determine its ability to pay claims, particularly where large or numerous small claims are made at the same time; and

(3) the effect of any limiting conditions and exclusion clauses that may restrict cover to a small number of specific operational losses and may exclude larger or hard to quantify indirect losses (such as lost business or reputational costs).

CHAPTER

SYSC 15A Operational resilience

Section : SYSC 15A.1 Application

Application

SYSC 15A.1.1 R This chapter applies to:

(1) a *firm* that is:

(a) an *enhanced scope SMCR firm*;

(b) a *bank*;

(c) a *designated investment firm*;

(d) a *building society*;

(e) a *Solvency II firm*,

(2) a *UK RIE*;

(3) an *electronic money institution*, a *payment institution* or a *registered account information service provider*; and

(4) a *consolidated tape provider*.

SYSC 15A.1.2 R In this chapter, a reference to a *firm* includes a *UK RIE*, an *electronic money institution*, a *payment institution*, a *registered account information service provider* and a *consolidated tape provider*.

SYSC 15A.1.3 R This chapter does not apply to a *TP firm*, a *TA PI firm*, *TA RAISP firm* or a *TA EMI firm*.

SYSC 15A.1.4 R This chapter does not apply to a *firm* which has its registered office (or, if it has no registered office, its head office) outside the *United Kingdom*.

SYSC 15A.1.5 R In this chapter, a reference to a *client* in relation to a *UK RIE* includes a *person* who is entitled, under an arrangement or agreement between them and that *UK RIE*, to use the *UK RIE's facilities*.

SYSC 15A.1.5A R This chapter applies in relation to a *consolidated tape provider* as if a reference to a *client* includes a *person* who purchases a *consolidated tape for bonds* from:

(a) a *consolidated tape provider*; or

(b) a *data vendor*.

SYSC 15A.1.6 R In this chapter, a reference to a *client* in relation to a *firm* carrying on the activity of *managing a UK UCITS* or *managing an AIF* includes:

(1) a *unitholder*; and

(2) an investor in an *AIF*.

SYSC 15A.1.7 R The requirements in this chapter apply with respect to:

(1) *regulated activities*;

(2) activities that constitute *dealing in investments as principal*, disregarding the exclusion in *article 15* of the *Regulated Activities Order* (Absence of holding out etc.);

(3) *ancillary activities*;

(4) in relation to *MiFID or equivalent third country business*, *ancillary services*;

(5) *collective portfolio management*;

(6) the provision of *payment services* and the issuance of *electronic money*, and activities connected to the provision of *payment services* and to the issuing of *electronic money* (whether or not the activity of issuing *electronic money* is specified in *article 9B* of the *Regulated Activities Order*);

(7) any other *unregulated activities*, but only in a *prudential context*; and

(8) *data reporting services* provided by a *consolidated tape provider*.

SYSC 15A.1.8 R Notwithstanding *SYSC 15A.1.7R*, where the requirements in this chapter apply to a *firm* only as a result of *SYSC 15A.1.1R(3)*, the requirements only apply to the provision of *payment services* and the issuance of *electronic money* by the *firm*, and activities connected to the provision of *payment services* and to the issuing of *electronic money* (whether or not the activity of issuing *electronic money* is specified in *article 9B* of the *Regulated Activities Order*).

SYSC 15A.1.9 R There is no territorial limitation on the application of this chapter.

Section : SYSC 15A.2 Operational resilience requirements

Important business services

SYSC 15A.2.1 R A *firm* must identify its *important business services*.

SYSC 15A.2.2 R A *firm* must keep its compliance with *SYSC 15A.2.1R* under review and, in particular, consider its compliance in the following circumstances:

(1) if there is a material change to the *firm's* business or the market in which it operates; and

(2) in any event, no later than 1 year after it last carried out the relevant assessment.

SYSC 15A.2.3 G In the course of identifying its *important business services* under *SYSC 15A.2.1R*, a *firm* should treat each distinct relevant service separately, and should not identify a collection of services as a single *important business service*.

SYSC 15A.2.4 G The factors that a *firm* should consider when identifying its *important business services* include, but are not limited to:

(1) the nature of the *client* base, including any vulnerabilities that would make the *person* more susceptible to harm from a disruption;

(2) the ability of *clients* to obtain the service from other providers (substitutability, availability and accessibility);

(3) the time criticality for *clients* receiving the service;

(4) the number of *clients* to whom the service is provided;

(5) the sensitivity of data held;

(6) potential to inhibit the functioning of the *UK financial system*;

(7) the *firm's* potential to impact the soundness, stability or resilience of the *UK financial system*;

(8) the possible impact on the *firm's* financial position and potential to threaten the *firm's* viability where this could harm the *firm's clients* or pose a risk to the soundness, stability or resilience of the *UK financial system* or the orderly operation of the financial markets;

(9) the potential to cause reputational damage to the *firm*, where this could harm the *firm's clients* or pose a risk to the soundness, stability or resilience of the *UK financial system* or the orderly operation of the financial markets;

(10) whether disruption to the services could amount to a breach of a legal or regulatory obligation;

(11) the level of inherent conduct and market risk;

(12) the potential to cause knock-on effects for other market participants, particularly those that provide financial market infrastructure or critical national infrastructure; and

(13) the importance of that service to the *UK financial system*, which may include

market share, *client* concentration and sensitive *clients* (for example, governments or pension funds).

Impact tolerances

SYSC 15A.2.5 R

A *firm* must, for each of its *important business services*, set an *impact tolerance*.

SYSC 15A.2.6 R

A *firm* must keep its compliance with *SYSC 15A.2.5R* under review and, in particular, consider its compliance in the following circumstances:

(1) if there is a material change to the *firm's* business or the market in which it operates; and

(2) in any event, no later than 1 year after it last carried out the relevant assessment.

SYSC 15A.2.7 G

The factors that a *firm* should consider when setting its *impact tolerance* include, but are not limited to:

(1) the nature of the *client* base, including any vulnerabilities that would make the *person* more susceptible to harm from a disruption;

(2) the number of *clients* that may be adversely impacted and the nature of the impact;

(3) the potential financial loss to *clients*;

(4) the potential financial loss to the *firm* where this could harm the *firm's clients* or pose a risk to the soundness, stability or resilience of the *UK financial system* or the orderly operation of the financial markets;

(5) the potential level of reputational damage to the *firm* where this could harm the *firm's clients* or pose a risk to the soundness, stability or resilience of the *UK financial system* or the orderly operation of the financial markets;

(6) the potential impact on market or consumer confidence;

(7) potential spread of risks to their other business services, other *firms* or the *UK financial system*;

(8) the potential loss of functionality or access for *clients*;

(9) any potential loss of confidentiality, integrity or availability of data;

(10) the potential aggregate impact of disruptions to multiple *important business services*, in particular where such services rely on common operational resources as identified by the *firm's* mapping exercise under *SYSC 15A.4.1R*.

SYSC 15A.2.8 G

When setting its *impact tolerance*, a *firm* should take account of the fluctuations in demand for its *important business service* at different times of the day and throughout the year in order to ensure that its *impact tolerance* reflects these fluctuations and is appropriate in light of the peak demand for the *important business service*.

SYSC 15A.2.9 R

A *firm* must ensure it can remain within its *impact tolerance* for each *important business service* in the event of a severe but plausible disruption to its operations.

SYSC 15A.2.10 G While under *SYSC 15A.2.9R* a *firm* must ensure it is able to remain within its *impact tolerance*, it should generally not do so if this would put the *firm* in breach of another regulatory obligation, conflict with the proper exercise of a discretion granted to it under any *rule* or regulation, or result in increased risk of harm to its *clients* or the soundness, stability or resilience of the *UK financial system* or the orderly operation of the financial markets. Under certain circumstances, a *firm* may wish to resume a degraded service. This is usually only appropriate if having regard to the interest of the *firm's clients*, the soundness, stability and resilience of the *UK financial system* and the orderly operation of the financial markets, the benefits of resuming a degraded service outweigh the negatives of keeping the service unavailable until the issues have been fully remediated and the service is able to be fully restored to its pre-disruption levels.

SYSC 15A.2.11 G Under *Principle* 11 (Relations with regulators), the *FCA* expects to be notified of any failure by a *firm* to meet an *impact tolerance*.

SYSC 15A.2.12 G When setting *impact tolerances* under *SYSC 15A.2.5R* a *payment services provider* should have regard to its obligations under the *EBA* Guidelines on ICT and security risk management.

SYSC 15A.2.13 G *Payment service providers* should have regard to the *impact tolerance* set under *SYSC 15A.2.5R* when complying with the *EBA* Guidelines on ICT and security risk management. In particular, they should, as part of their continuity planning and testing, consider their ability to remain within their *impact tolerance* through a range of severe but plausible disruption scenarios.

Section : SYSC 15A.3 Strategies, processes and systems

SYSC 15A.3.1	R	A *firm* must have in place sound, effective and comprehensive strategies, processes and systems to enable it to comply with its obligations under this chapter.
SYSC 15A.3.2	R	The strategies, processes and systems required under *SYSC 15A.3.1R* must be comprehensive and proportionate to the nature, scale and complexity of the *firm's* activities.

Section : SYSC 15A.4 Mapping

SYSC 15A.4.1	R	A *firm* must identify and document the people, processes, technology, facilities and information necessary to deliver each of its *important business services*. This must be sufficient to allow the *firm* to identify vulnerabilities and remedy these as appropriate.
SYSC 15A.4.2	G	Where a *firm* relies on a third party for the delivery of an *important business service*, we would expect the *firm* to have sufficient understanding of the people, processes, technology, facilities, and information that support the provision by the third party of its services to or on behalf of the *firm* so as to allow the *firm* to comply with its obligations under *SYSC 15A.4.1R*.
SYSC 15A.4.3	R	A *firm* must keep its compliance with *SYSC 15A.4.1R* under review and, in particular, review its compliance in the following circumstances: (1) if there is a material change to the *firm's* business, the *important business services* identified in accordance with *SYSC 15A.2.1R* or *impact tolerances* set in accordance with *SYSC 15A.2.5R*; and (2) in any event, no later than 1 year after it last carried out the relevant assessment.

Section : SYSC 15A.5 Scenario testing

Testing plan

SYSC 15A.5.1 R A *firm* must develop and keep up to date a testing plan that appropriately details how it will gain assurance that it can remain within the *impact tolerances* for each of its *important business services*.

SYSC 15A.5.2 G *Firms* should ensure that the testing plan takes account of a number of factors, including but not limited to:

(1) the type of scenario testing undertaken. For example, whether it is paper based, simulations or through the use of live-systems;

(2) the scenarios which the *firm* expects to be able to remain within their *impact tolerances* and which ones they may not;

(3) the frequency of the testing;

(4) the number of *important business services* tested;

(5) the availability and integrity of supporting assets;

(6) how the *firm* would communicate with internal and external stakeholders effectively to reduce the harm caused by operational disruptions.

Testing

SYSC 15A.5.3 R A *firm* must carry out scenario testing, to assess its ability to remain within its *impact tolerance* for each of its *important business services* in the event of a severe but plausible disruption of its operations.

SYSC 15A.5.4 R In carrying out the scenario testing, a *firm* must identify an appropriate range of adverse circumstances of varying nature, severity and duration relevant to its business and risk profile and consider the risks to the delivery of the *firm's important business services* in those circumstances.

SYSC 15A.5.5 G Where a *firm* relies on a third party for the delivery of its *important business services*, we would expect the *firm* to work with the third party to ensure the validity of the *firm's* scenario testing under *SYSC 15A.5.3R*. To the extent that the *firm* relies on the third party to carry out testing of the services provided by the third party to or on behalf of the *firm*, the *firm* should ensure the suitability of the methodologies, scenarios and considerations adopted by the third party in carrying out testing. The *firm* is ultimately responsible for the quality and accuracy of any testing carried out, whether by the *firm* or by a third party.

SYSC 15A.5.6 G In carrying out the scenario testing, a *firm* should, among other things, consider the following scenarios:

(1) corruption, deletion or manipulation of data critical to the delivery of its *important business services*;

(2) unavailability of facilities or key people;

(3) unavailability of third party services, which are critical to the delivery of its *important business services*;

(4) disruption to other market participants, where applicable; and

(5) loss or reduced provision of technology underpinning the delivery of *important business services*.

SYSC 15A.5.7 R

A *firm* must carry out the scenario testing:

(1) if there is a material change to the *firm's* business, the *important business services* identified in accordance with *SYSC 15A.2.1R* or impact tolerances set in accordance with *SYSC 15A.2.5R*;

(2) following improvements made by the *firm* in response to a previous test; and

(3) in any event, on a regular basis.

Lessons learned

SYSC 15A.5.8 R

A *firm* must, following scenario testing or, in the event of an operational disruption, after such event, conduct a lessons learned exercise that allows the *firm* to identify weaknesses and take action to improve its ability to effectively respond and recover from future disruptions.

SYSC 15A.5.9 R

Following the lessons learned exercise, a *firm* must make necessary improvements to address weaknesses identified to ensure that it can remain within its *impact tolerances* in accordance with *SYSC 15A.2.9R*.

Section : SYSC 15A.6 Self-assessment and lessons learned exercise documentation

SYSC 15A.6.1 R

A *firm* must make, and keep up to date, a written record of its assessment of its compliance with the requirements in this chapter, including, but not limited to, a written record of:

(1) *important business services* identified by the *firm* and the justification for the determination made;

(2) the *firm's impact tolerances* and the justification for the level at which they have been set by the *firm*;

(3) the *firm's* approach to mapping under *SYSC 15A.4.1R*, including how the *firm* has used mapping to:

(a) identify the people, processes, technology, facilities and information necessary to deliver each of its *important business services*;

(b) identify vulnerabilities; and

(c) support scenario testing;

(4) the *firm's* testing plan and a justification for the plan adopted;

(5) details of the scenario testing carried out as part of its obligations under *SYSC 15A.5*, including a description and justification of the assumptions made in relation to scenario design and any identified risks to the *firm's* ability to meet its *impact tolerances*;

(6) any lessons learned exercise conducted under *SYSC 15A.5.8R*;

(7) an identification of the vulnerabilities that threaten the *firm's* ability to deliver its *important business services* within the *impact tolerances* set, including the actions taken or planned and justifications for their completion time;

(8) its communication strategy under *SYSC 15A.8.1R* and an explanation of how it will enable it to reduce the anticipated harm caused by operational disruptions; and

(9) the methodologies used to undertake the above activities.

SYSC 15A.6.2 R

A *firm* must retain each version of the records referred to in *SYSC 15A.6.1R* for at least 6 years and, on request, provide these to the *FCA*.

Section : SYSC 15A.7 Governance

SYSC 15A.7.1	R	A *firm* must ensure that its *governing body* approves and regularly reviews the written records required under *SYSC 15A.6* (Self-assessment and lessons learned exercise documentation).

Section : SYSC 15A.8 Communications

SYSC 15A.8.1	R	A *firm* must maintain an internal and external communication strategy to act quickly and effectively to reduce the anticipated harm caused by operational disruptions.
SYSC 15A.8.2	G	As part of a *firm's* communications strategy, the *FCA* expects the *firm* to: (1) consider, in advance of a disruption, how it would provide important warnings or advice quickly to *clients* and other stakeholders, including where there is no direct line of communication; (2) use effective communication to gather information about the cause, extent, and impact of operational incidents; and (3) ensure that their choice of communication method takes account of the circumstances, needs and vulnerabilities of their *clients* and other stakeholders.
SYSC 15A.8.3	R	A *firm* must provide clear, timely and relevant communications to stakeholders in the event of an operational disruption.

Section : SYSC 15A.9 Supervisory review and feedback

SYSC 15A.9.1	G	The *FCA* may provide individual *guidance* as to whether a *firm's* compliance with this chapter is adequate and, if necessary, require a *firm* to take the necessary actions or steps to address any failure to meet the requirements in this chapter.
SYSC 15A.9.2	G	A *firm* should have regard to the views provided by the *FCA* in relation to the *firm's* compliance. If a *firm* considers that any individual *guidance* given to it is inappropriate to its circumstances it should, consistent with *Principle* 11 (Relations with regulators), inform the *FCA* that it disagrees with that *guidance*. The *FCA* may reissue the individual *guidance* if, after discussion with the *firm*, the *FCA* concludes that the appropriate actions or steps a *firm* should take is different from that initially suggested by the *FCA*.
SYSC 15A.9.3	G	If, after discussion, the *FCA* and a *firm* still do not agree, the *FCA* may consider other tools available to it, including its powers under *sections 55J* and *55L* of the *Act* on its own initiative to require the *firm* to take specific steps in line with the *FCA's* view to comply with the requirements in this chapter.